

TOP 10 DE OWASP Y PRÁCTICAS DE SEGURIDAD PARA APLICACIONES WEB

V. E. Gonzalez Ortiz

7690-13-11075 Universidad Mariano Gálvez

Desarrollo Web

vgonzalezo@miumg.edu.gt

1. Resumen

Este trabajo analiza las vulnerabilidades más comunes en aplicaciones web, descritas en el top 10 de OWASP, y presenta prácticas de seguridad recomendadas para mitigar dichos riesgos. Entre las amenazas se encuentran la inyección de código, la autenticación rota y la exposición de datos sensibles. Se revisan medidas como el uso de cifrado robusto, la implementación de controles de acceso seguros y la validación estricta de las entradas del usuario. El artículo concluye con la importancia de aplicar un enfoque integral de seguridad desde las primeras fases del desarrollo para garantizar la protección de las aplicaciones web.

2. Palabras clave

OWASP, Seguridad web, Vulnerabilidades, Prácticas de seguridad, Cifrado

3. Desarrollo del tema

3.1. OWASP

El Proyecto abierto de seguridad de aplicaciones web (OWASP) es una fundación sin fines de lucro cuyo objetivo principal es mejorar la seguridad de las aplicaciones web. Se enfoca en identificar y solucionar las vulnerabilidades más críticas que pueden estar presentes en aplicaciones web y otros tipos de software, proporcionando una serie de recursos abiertos y gratuitos que los desarrolladores, auditores de seguridad, y organizaciones pueden utilizar para mejorar la seguridad dentro del desarrollo de proyectos web. Fundada en 2001 y ha tenido un amplio crecimiento para convertirse en una referencia global en la seguridad de aplicaciones. Lo que distingue a OWASP es que sus proyectos, documentacion y soluciones son de código abierto, lo que permite que la comunidad pueda adoptar, contribuir y mantener las mejores prácticas accesibles para todos.

OWASP Top 10

La ultima actualizacion del listado de OWASP es del 2021 la cual actualiza y reemplaza sobre las ultima actualizacion del 2017, El listado ahora incluye:

1. **A03:2021 Control de acceso roto:** El control de acceso roto ocurre cuando las aplicaciones no implementan correctamente las políticas que deben restringir el acceso a datos y funciones. Esto permite que usuarios no autorizados puedan realizar acciones fuera de sus permisos. Las vulnerabilidades de control de acceso roto pueden incluir la posibilidad de modificar roles de usuario sin autorización, ver datos confidenciales a los que no se debería tener acceso, o realizar acciones administrativas sin ser un administrador. **Solucion:** las apli-

caciones deben utilizar controles de acceso basados en roles estrictos y robustos, asegurar que cada recurso sensible esté protegido, y realizar auditorías frecuentes del sistema para identificar fallos.

2. **A02:2021 – Fallos criptográficos:** Los fallos criptográficos surgen cuando los mecanismos utilizados para proteger los datos no son adecuados o no se implementan correctamente. Esto puede incluir el uso de algoritmos de cifrado débiles, claves de cifrado mal gestionadas, o la falta de cifrado en datos sensibles. Estos fallos pueden comprometer la confidencialidad y la integridad de la información, permitiendo que los atacantes accedan a datos sensibles como contraseñas, números de tarjetas de crédito o información personal. **Solución:** las aplicaciones deben usar algoritmos criptográficos fuertes, manejar adecuadamente las claves, y garantizar que todos los datos sensibles estén protegidos tanto en tránsito como en reposo.
3. **A03:2021 – Inyección:** Las inyecciones, como las inyecciones SQL o de comandos, ocurren cuando un atacante logra ejecutar comandos maliciosos en una aplicación aprovechando entradas no seguras. Las inyecciones son peligrosas porque permiten que los atacantes interfieran con las consultas de bases de datos, manipulen datos o tomen control del servidor. Estas vulnerabilidades suelen explotarse cuando no se validan o limpian correctamente las entradas de usuario, permitiendo que el código malicioso sea ejecutado. **Solución:** es fundamental validar y sanear todas las entradas de usuario, usar consultas parametrizadas y evitar directamente la ejecución de entradas sin verificar.
4. **A04:2021 – Diseño inseguro:** El diseño inseguro es un enfoque incorrecto desde el inicio del desarrollo de una aplicación, donde no se consideran los principios de seguridad durante la fase de diseño. Esta falta de planificación adecuada deja la aplicación expuesta a múltiples

tipos de ataques. Algunos ejemplos incluyen no prever mecanismos adecuados de autenticación, no incorporar cifrado, o no planificar estrategias de recuperación ante fallos. Para contrarrestar esto, los equipos de desarrollo deben incluir buenas prácticas de seguridad en todas las etapas del ciclo de vida del software, realizar análisis de amenazas y adoptar un enfoque de "seguridad por diseño".

5. **A05:2021 – Mala configuración de seguridad:** La mala configuración de seguridad ocurre cuando las configuraciones de seguridad predeterminadas no se modifican adecuadamente o se dejan expuestas accidentalmente. Esto puede incluir dejar activos paneles de administración abiertos al público, utilizar configuraciones por defecto en servidores o bases de datos, o mostrar mensajes de error detallados que revelan información sensible. **Solucion:** se deben eliminar o deshabilitar todas las funciones innecesarias, proteger adecuadamente los paneles administrativos y limitar la información que se muestra en mensajes de error.
6. **A06:2021 – Componentes vulnerables y desactualizados:** El uso de componentes vulnerables o desactualizados, como bibliotecas de código, frameworks o plugins, representa un riesgo grave porque los atacantes pueden explotar las vulnerabilidades conocidas en esos componentes. Las aplicaciones modernas suelen depender de múltiples dependencias externas, lo que amplía la superficie de ataque si esos componentes no se mantienen actualizados. Para mitigar este riesgo, es fundamental que los desarrolladores mantengan los componentes actualizados, utilicen fuentes confiables para obtener bibliotecas, y eliminen cualquier componente que ya no sea necesario en la aplicación.
7. **A07:2021 – Fallos en la identificación y autenticación:** Las fallas en los mecanismos de identificación y autenticación permiten que los atacantes comprometan cuentas de usuarios

o suplanten su identidad. Este problema se agrava si se permiten contraseñas débiles, si no se implementa la autenticación multifactor (MFA) o si no se protegen adecuadamente las sesiones. Estas fallas permiten que un atacante acceda a recursos sensibles o tome control de cuentas de usuarios privilegiados. **Solucion:** es esencial implementar MFA, forzar políticas de contraseñas seguras y proteger las sesiones con tokens de autenticación robustos.

8. **A08:2021 – Fallos de integridad de software y datos:** Los fallos de integridad de software y datos ocurren cuando las actualizaciones, librerías y otros elementos esenciales de la aplicación no se verifican adecuadamente para asegurar que no han sido manipulados. Los ataques pueden ocurrir cuando los sistemas de actualización no están protegidos o si los desarrolladores confían en fuentes no verificadas. Los atacantes pueden inyectar código malicioso o manipular datos importantes, comprometiendo la seguridad del sistema. **Solucion:** verificar la integridad de los paquetes y utilizar firmas digitales o hashes seguros para confirmar que no han sido modificados.

9. **A09:2021 – Fallos en el monitoreo y registro de seguridad:** Los fallos en el monitoreo y registro de seguridad permiten que los ataques pasen desapercibidos durante largos periodos de tiempo, lo que dificulta la detección de intrusiones y el análisis posterior. La falta de registro adecuado o la ausencia de alertas en eventos críticos permite a los atacantes operar sin ser detectados, lo que puede llevar a brechas de seguridad que permanecen sin respuesta durante meses. **Solucion:** es importante implementar un sistema de registro y monitoreo eficiente que permita detectar comportamientos sospechosos en tiempo real y establecer planes de respuesta a incidentes.

10. **A10:2021 – Falsificación de solicitud del lado del servidor:** La falsificación de solicitudes

del lado del servidor (SSRF) es una vulnerabilidad que ocurre cuando una aplicación web permite que un atacante envíe solicitudes manipuladas desde el servidor a recursos internos o externos sin la debida validación. Esto puede permitir que un atacante acceda a sistemas internos de la red que, de otro modo, no estarían disponibles desde el exterior. **Solucion:** es fundamental validar y sanear todas las solicitudes que el servidor realiza hacia recursos externos, limitar las direcciones a las que se puede acceder y monitorear las actividades sospechosas relacionadas con solicitudes hacia servidores internos o externos.

3.2. prácticas de seguridad para aplicaciones web

Con la creciente implementacion de aplicaciones web, la ciberseguridad es uno de los puntos mas importantes a considerar, dado que una brecha de seguridad como la perdida de datos puede tener altos costos a las organizaciones y empresas. Incorporar la seguridad en el ciclo de vida del desarrollo de aplicaciones es de vital importancia, por lo se puede seguir las siguientes recomendaciones

1. **Proveedores de seguridad** Se puede tener el sericio de proveedores especializados en seguridad, esto para poder mejorar las aplicaciones, un proveedor puede garantizar una unicamente puerta de entrada a la aplicacion como protocolos como OAuth, SAML, SSO y OpenID Connect.
2. **HTTPS** Dado que las aplicaciones we se ejecutan a travez de internet, se debe de aplicar que se ejecute en HTTPS, esto proporciona una capa de seguridad contra ciberdelincuentes cifando la informacion que se transmite entre backend y frontend
3. **Planes de prueba de calidad** Es importante que por todos los cambios o implementaciones

realizadas se deben de tener por un ciclo de prueba de control para asegurar que no se encuentren brechas de seguridad que puedan ser potenciales vulnerabilidades que aprovechen los atacantes.

4. **Cifrar datos** Dado que las aplicaciones web pueden tener datos confidenciales como la informacion personal sensible de las personas asi como datos bancarios y de tarjetas, es importante tener estos datos cifrados, para poder tener seguridad adicional en caso de filtracion de datos o ataques.
5. **Auditorias constantes** Se puede realizar auditorias sobre vulneabilidades para poder detectarlas y asi poder aplicar soluciones.

4. Observaciones y comentarios

1. Las prácticas de seguridad para aplicaciones web deben estar integradas en todas las fases del ciclo de desarrollo.
2. Implementar controles de seguridad sólidos y realizar auditorías continuas son aspectos claves para mantener la seguridad a largo plazo.
3. Las empresas deben fomentar una cultura de seguridad que involucre a todos los miembros del equipo de desarrollo.

5. Conclusiones

1. El OWASP Top 10 sigue siendo un referente clave para identificar y mitigar las vulnerabilidades en aplicaciones web.
2. Las prácticas de seguridad, como el cifrado de datos y la autenticación segura, son esenciales para proteger aplicaciones modernas.
3. La implementación de seguridad debe integrarse desde las primeras etapas del desarrollo para lograr un entorno más seguro.

6. Referencias

- OWASP. (s.f.). OWASP Top Ten Web Application Security Risks. <https://owasp.org/www-project-top-ten/>
- Cloudflare. (s.f.). OWASP Top 10. <https://www.cloudflare.com/es-es/learning/security/threats/owasp-top-10/>
- Check Point. (s.f.). OWASP Top 10 Vulnerabilities. <https://checkpoint.com/es/cyber-hub/cloud-security/what-is-application-security-appsec/owasp-top-10-vulnerabilities/>
- OWASP. (s.f.). OWASP Top 10 (Spanish). <https://owasp.org/Top10/es/>
- Jitterbit. (s.f.). Web Application Security Best Practices. <https://www.jitterbit.com/es/blog/web-application-security-best-practices/>